

Curso de Especialización Ciberseguridad en las TIC

Práctica 3. Política de contraseñas seguras en Windows y GNU/Linux

Objetivos

- Diseñar una combinación de mecanismos de autenticación.
- Describir el protocolo utilizado y la política de autenticación utilizada.
- Implementar el reconocimiento biométrico como mecanismos de autenticación en un equipo Windows 11 y GNU/Linux.

Resumen

Autora: Marina del Pilar López Oliva

Diciembre 2025

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	10/12/2025	Configuración de la plantilla.
1.1	14/12/2025	Realización de la práctica.

Índice de Contenidos

1. Introducción.....	4
2. Apartado 1.....	4
3. Apartado 2.....	5
4. Apartado 3. Política por defecto.....	6
5. Apartado 4. Diseño de la política para el subsistema.....	7
6. Apartado 5. Política por defecto.....	12
7. Apartado 6. Diseño de la política para el subsistema.....	13
8. Apartado 7.....	18
9. Conclusiones.....	18
10. Webgrafía.....	19

1. Introducción

La correcta gestión de credenciales es fundamental para preservar la confidencialidad de la información. En este caso, como es un centro educativo, maneja perfiles de usuarios diversos y altos niveles de rotación.

Esta práctica se centra en implementar políticas de contraseña robustas en los sistemas Windows Server y Ubuntu Server. Mitigando así las vulnerabilidades como el cracking o el uso de fuerza bruta.

2. Apartado 1.

En el entorno del centro educativo, se manejan diversos perfiles de usuario y unidades organizativas. Los principales tipos de credenciales identificados son:

- **Credenciales de dominio (Active Directory):** autenticación centralizada en red Windows. Se utiliza para accesos a equipos del aula, recursos compartidos y servicios de red. Este tipo de credenciales permite aplicar políticas de seguridad de forma homogénea en todo el dominio.
- **Credenciales locales:** cuentas locales en equipos o servidores. Se emplean para el mantenimiento de servidores Ubuntu o equipos aislados.
- **Credenciales administrativas:** cuentas con privilegios elevados. Estas credenciales permiten la gestión del sistema, la instalación de software, la modificación de configuraciones críticas y la aplicación de políticas de seguridad, por lo que su compromiso tendría un impacto crítico en la infraestructura del centro.
- **Credenciales de servicio:** cuentas utilizadas por aplicaciones o servicios. Se usan para servicios web, bases de datos, plataformas educativas y tareas de automatización. Aunque no sean utilizadas por personas, deben protegerse adecuadamente para evitar acceso indebidos o escaladas de privilegios.

La política de contraseñas debe proteger especialmente las credenciales de dominio y administrativas, ya que su compromiso puede afectar a un gran número de usuarios y recursos del centro educativo, comprometiendo la seguridad de toda la infraestructura.

3. Apartado 2.

La autenticación de usuarios en los sistemas de información puede basarse en uno o varios factores, cuyo objetivo es verificar de forma fiable la identidad del usuario. Estos mecanismos, en nuestro centro, deben equilibrar la seguridad, la facilidad de uso y la escalabilidad, debido al elevado número de usuarios y a la diversidad de perfiles existentes.

Los principales factores de autenticación son los siguientes:

- **Conocimiento.** Se basa en algo que el usuario conoce, como contraseñas o frases de paso. Dado que este factor es vulnerable a ataques de fuerza bruta, diccionario o reutilización, se reforzará mediante políticas de complejidad, longitud mínima, historial de contraseñas, caducidad y bloqueo de cuentas tras intentos fallidos.
- **Posesión.** Se basa en algo que el usuario posee, como tarjetas identificativas, tokens físicos o YubiKey. Aunque este factor no se implanta directamente en esta práctica, puede utilizarse como complemento en entornos más críticos del centro educativo, como personal administrativo o docente con acceso a información sensible.
- **Inherente.** Se basa en características propias del usuario, como la huella dactilar o el reconocimiento facial. Este tipo de autenticación es habitual en el control de acceso físico o en equipos de uso restringido. Su uso mejora la seguridad al dificultar la suplantación de identidad. Este tipo de factor sería el que hemos intentado implementar en la práctica anterior. Así que es un factor que también tendríamos en un centro educativo real.

En esta práctica nos centraremos en fortalecer el factor conocimiento (contraseña), ya que es el más utilizado en los sistemas Windows y Ubuntu, y el más adecuado para un entorno educativo con gran volumen de usuario. La aplicación de políticas de contraseñas robustas permite reducir significativamente el riesgo de compromiso de cuentas sin afectar de forma excesiva a la usabilidad del sistema.

4. Apartado 3. Política por defecto

Windows Server 2025, como controlador de dominio, aplica una política contraseña por defecto gestionada a través de Active Directory. Esta configuración inicial está pensada para ofrecer un nivel básico de seguridad, pero resulta insuficiente en un entorno educativo. Ya que los centros educativos suelen tener un número elevado de usuarios, cuentas compartidas en aulas y una alta rotación de usuarios.

Directiva	Configuración de directiva
Almacenar contraseñas con cifrado reversible	Deshabilitada
Auditoría de longitud mínima de contraseña	No está definido
Exigir historial de contraseñas	24 contraseñas recordadas
La contraseña debe cumplir los requisitos de complejidad	Habilitada
Longitud mínima de la contraseña	7 caracteres
Reducir los límites de longitud mínima de la contraseña	No está definido
Vigencia máxima de la contraseña	42 días
Vigencia mínima de la contraseña	1 días

Figura 1. Políticas de contraseña por defecto en Windows Server 2025.

Directiva	Configuración de directiva
Duración del bloqueo de cuenta	No está definido
Permitir bloqueo de cuenta de administrador	No está definido
Restablecer el bloqueo de cuenta después de	No está definido
Umbral de bloqueo de cuenta	0 intentos de inicio de sesión no...

Figura 2. Políticas de bloqueo de cuentas por defecto en Windows Server 2025.

En esta imagen se muestran las políticas de contraseñas establecidas por defecto en Windows Server 2025. A partir de esta configuración, identificamos los parámetros:

- Longitud mínima de 7 caracteres.
- Están habilitados los requisitos de complejidad. La contraseña debe cumplir al menos tres de las cuatro categorías (mayúsculas, minúsculas, números y símbolos).
- No se aplica bloqueo automático de la cuenta tras múltiples intentos de acceso fallidos..

Esta configuración presenta diversas debilidades desde el punto de vista de seguridad:

- La longitud mínima de 7 caracteres resulta insuficiente en el contexto actual. Pues facilita ataques de fuerza bruta y por diccionario, especialmente en un entorno con numerosos usuarios.
- Aunque la complejidad esté habilitada, no compensa la longitud insuficiente, ya que las contraseñas siguen siendo vulnerables.
- La política por defecto no establece un bloqueo automático de cuentas tras intentos fallidos, lo que facilita ataques de fuerza bruta contra cuentas de dirección o altos cargos.

En consecuencia, las políticas de contraseñas por defecto en Windows Server 2025 deben ser reforzadas para adaptarse a las necesidades de seguridad de un centro educativo, y mitigar los riesgos derivados de accesos no autorizados.

5. Apartado 4. Diseño de la política para el subsistema

Hemos diseñado una política adaptada al centro educativo IES Camp de Morvedre, considerando la necesidad de evitar ataques de fuerza bruta y garantizar contraseñas robustas.

- Longitud mínima de 12 caracteres, para dificultar ataques de fuerza bruta.
- Habilitar el historial de contraseñas, mínimo recordando 3 contraseñas. Así evitamos la reutilización inmediata.
- Mantener la complejidad habilitada, obligando a usar mayúsculas, minúsculas, números y símbolos.
- Establecer un umbral de bloque de 4 intentos fallidos. Con esto mitigamos los ataques de fuerza bruta automatizados.
- Bloquear la cuenta durante 60 minutos, lo que desalienta los intentos persistentes.
- Tener un máximo de vida para las contraseñas de 90 días. Es un equilibrio entre la seguridad, la usabilidad y la comodidad de los usuarios.

Directiva	Configuración de directiva
 Almacenar contraseñas con cifrado reversible	Deshabilitada
 Auditoría de longitud mínima de contraseña	No está definido
 Exigir historial de contraseñas	3 contraseñas recordadas
 La contraseña debe cumplir los requisitos de complejidad	Habilitada
 Longitud mínima de la contraseña	12 caracteres
 Reducir los límites de longitud mínima de la contraseña	No está definido
 Vigencia máxima de la contraseña	90 días
 Vigencia mínima de la contraseña	1 días

Figura 3. Políticas de contraseña establecidas en Windows Server 2025.

Directiva	Configuración de directiva
 Duración del bloqueo de cuenta	60 minutos
 Permitir bloqueo de cuenta de administrador	Habilitada
 Restablecer el bloqueo de cuenta después de	10 minutos
 Umbral de bloqueo de cuenta	4 intentos de inicio de sesión no...

Figura 4. Políticas de bloqueo de cuentas establecidas en Windows Server 2025.

Vamos a verificar el correcto funcionamiento de estas políticas. Intentaremos acceder con el usuario “salbam” y tendremos 5 intentos fallidos de inicio de sesión desde un equipo cliente Windows 11.

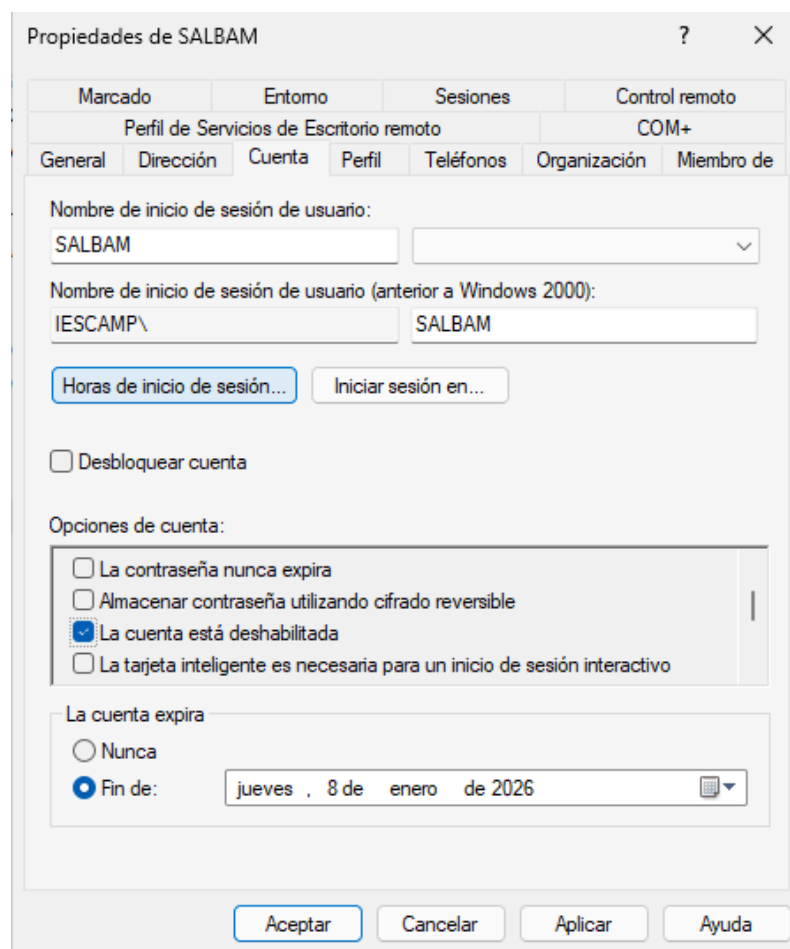


Figura 5. Cuenta deshabilitada después de 5 intentos fallidos de acceso.

La cuenta está bloqueada porque hemos intentado 5 accesos sin éxito. Al cabo de 60 minutos nos debe dejar entrar de nuevo.

Cuando intentamos cambiar contraseñas sin cumplir con los requisitos en las políticas, nos saldrá un mensaje de error. Solo cuando la cambiemos correctamente nos dejará.

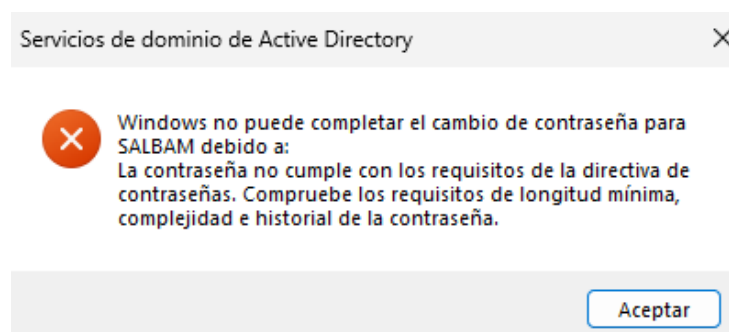


Figura 6. Error por intentar cambiar la contraseña por una que no cumple con las políticas.

La cuenta Administrador puede bloquearse al alcanzar el umbral de intentos fallidos establecido en la política. Esto permite aplicar de manera uniforme las medidas de seguridad y proteger la cuenta contra intentos de acceso no autorizados.

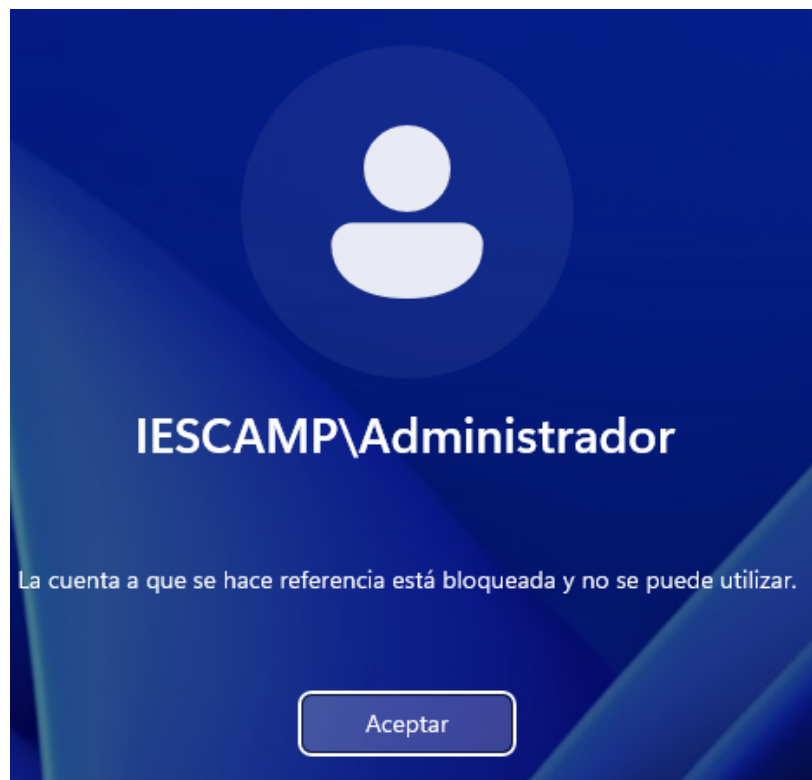


Figura 7. Cuenta del administrador bloqueada después de 5 intentos fallidos.

Esto pasa porque tenemos un segundo administrador que puede desbloquear la cuenta. Si no fuera el caso, y solo tuviéramos uno, no se bloquearía para evitar ataques DoS.

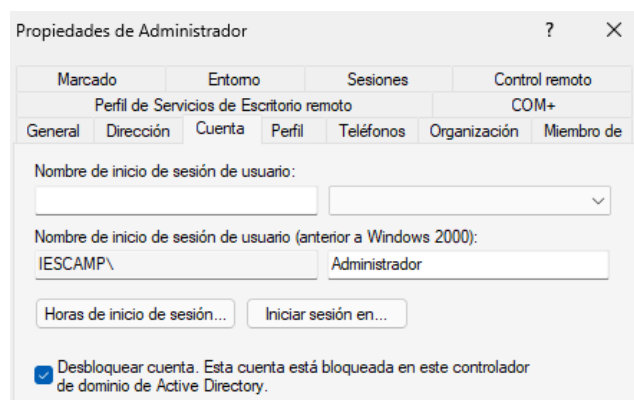


Figura 8. Desbloqueo del administrador desde el otro administrador mlopez.

Si configuramos la auditoría de inicios de sesión en la directiva de seguridad, podemos visualizar los eventos de inicio de sesión.

Directiva	Configuración de directiva
Auditar el acceso a objetos	No está definido
Auditar el acceso al servicio de directorio	No está definido
Auditar el cambio de directivas	No está definido
Auditar el seguimiento de procesos	No está definido
Auditar el uso de privilegios	No está definido
Auditar eventos de inicio de sesión	Correcto, Erróneo
Auditar eventos de inicio de sesión de cuenta	Correcto, Erróneo
Auditar eventos del sistema	No está definido
Auditar la administración de cuentas	No está definido

Figura 9. Activación de la auditoría de eventos de inicio de sesión.

Filtrados:Registro: Security; Origen: ; Id. del evento: 4624. Número de eventos: 1.177				
Palabras clave	Fecha y hora	Origen	Id. del evento	Categoría de la ...
Auditoría cor...	10/12/2025 21:12:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:12:15	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:11:01	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:11:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:12:16	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:15:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:16:01	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:13:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:14:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:08:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:09:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:07:10	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:07:11	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:10:07	Microsoft Win...	4624	Logon
Auditoría cor...	10/12/2025 21:11:01	Microsoft Win...	4624	Logon

Figura 10. Eventos de inicio de sesión correctos.

Filtrados:Registro: Security; Origen: ; Id. del evento: 4625. Número de eventos: 15				
Palabras clave	Fecha y hora	Origen	Id. del evento	Categoría de la ...
Error de audi...	10/12/2025 22:26:31	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 22:26:29	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 22:26:28	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 22:26:33	Microsoft Win...	4625	Account Lockout
Error de audi...	10/12/2025 22:28:23	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 22:28:09	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 22:27:13	Microsoft Win...	4625	Account Lockout
Error de audi...	10/12/2025 22:26:26	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 19:45:44	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 18:08:46	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 17:44:55	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 19:47:08	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 21:19:28	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 19:50:43	Microsoft Win...	4625	Logon
Error de audi...	10/12/2025 19:48:25	Microsoft Win...	4625	Logon

Figura 11. Eventos de inicio de sesión fallidos.

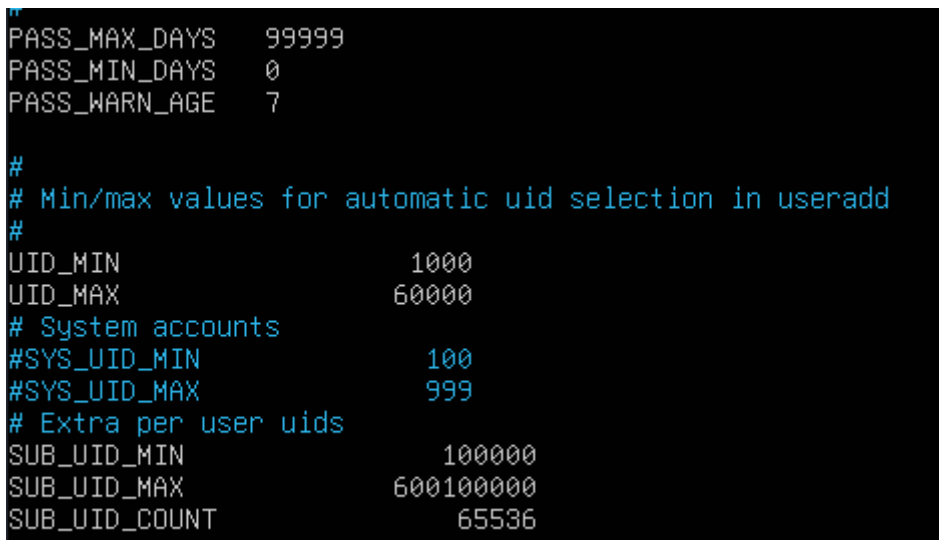
Con esto se muestra los eventos de los usuarios en cuanto al inicio de sesión. Así comprobamos el registro en el Visor de Eventos (Seguridad). Estos eventos permiten verificar el cumplimiento de la política de seguridad y monitorizar internos de acceso no autorizados. Se pueden ver incluso cuando se bloquea la cuenta.

6. Apartado 5. Política por defecto.

Ubuntu Server gestiona la autenticación mediante PAM. Por defecto, las políticas de seguridad de contraseñas son permisivas y presentan vulnerabilidades que deben corregirse para entornos educativos.

El archivo `/etc/login.defs` define las políticas de caducidad y administración de contraseñas, como:

- El máximo de días antes de requerir cambio de contraseñas. Por defecto es nunca.
- El mínimo de días entre cambios, de normal está en 0.
- Se especifican 7 días de avisos previos antes de la expiración.
- La longitud mínima de la contraseña es de 5-8 caracteres.
- Se suele cifrar las contraseñas con sha 512.



```
PASS_MAX_DAYS 99999
PASS_MIN_DAYS 0
PASS_WARN_AGE 7

#
# Min/max values for automatic uid selection in useradd
#
UID_MIN 1000
UID_MAX 60000
# System accounts
#SYS_UID_MIN 100
#SYS_UID_MAX 999
# Extra per user uids
SUB_UID_MIN 100000
SUB_UID_MAX 600100000
SUB_UID_COUNT 65536
```

Figura 12. Archivo `login.defs` por defecto respecto a las contraseñas.

El archivo `/etc/pam.d/common-password` utiliza `pam_unix.so` para validar contraseñas. Por defecto no exige complejidad, no previene reutilización de contraseñas anteriores, y no se verifica las palabras de diccionario.

```
# here are the per-package modules (the "Primary" block)
password [success=1 default=ignore] pam_unix.so obscure yescrypt
# here's the fallback if no module succeeds
password requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password required pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

Figura 13. Archivo common-password por defecto.

En /etc/shadow se almacenan las contraseñas, normalmente cifradas con sha 512. Contiene la información de: último cambio, caducidad, inactividad y expiración de la cuenta.

En resumen las configuraciones por defecto suelen ser:

- No tiene caducidad de contraseñas.
- La longitud mínima es de 5-8 caracteres.
- No tiene complejidad obligatoria.
- No se controla la reutilización de contraseñas.
- No se implementa la protección contra diccionarios o ataques de fuerza bruta.
- No se configura el bloqueo de cuenta tras intentos fallidos.

En resumen, la configuración por defecto en Ubuntu Server es permisiva y no garantiza seguridad frente a ataques. Para un entorno educativo se recomienda fortalecer las políticas mediante libpam-pwquality y configurar login.defs para la caducidad, complejidad y control de reutilización.

7. Apartado 6. Diseño de la política para el subsistema.

Vamos a establecer una política de contraseñas robustas para usuarios del subsistema Ubuntu Server, considerando las vulnerabilidades comunes en sistemas linux. Como pueden ser los ataques de fuerza bruta, diccionario, reutilización de contraseñas y contraseñas débiles.

Buscamos garantizar una política de contraseñas teniendo en cuenta la coherencia de nuestro subsistema.

- En el archivo pwquality.conf configuramos la complejidad de las contraseñas:
 - Longitud mínima de 15 caracteres.

- Uso obligatorio de 4 tipos de caracteres.
- Diferencia mínima de 5 caracteres con la contraseña anterior.
- Máximo dos repeticiones consecutivas del mismo carácter.
- Máximo cuatro caracteres consecutivos de la misma clase.
- No permitir datos personales del usuario en la contraseña.
- Evitar palabras comunes.
- Configuración del archivo common-password para el historial y el cifrado:
 - Recordar las últimas 5 contraseñas para evitar repeticiones.
 - Hash de contraseñas sha 512, seguro contra ataques de fuerza bruta.
- Configurar archivos login.defs y chage para la caducidad y los avisos:
 - Máximo de 90 días de vida de la contraseña.
 - 7 días de aviso previo a la caducidad.
 - La cuenta se desactiva tras 30 días sin uso.
- Bloqueo automático de cuenta durante 60 minutos tras 5 intentos fallidos.

Las políticas aseguran robustez de seguridad con usabilidad para alumnos y profesores.

```
difok = 5
#
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 15
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
dcredit = -2
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
ucredit = -2
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
lcredit = -2
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
ocredit = -2
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
minclass = 4
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
maxrepeat = 2
#
# The maximum number of allowed consecutive characters of the same class in the
# new password.
# The check is disabled if the value is 0.
maxclassrepeat = 4
#
# Whether to check for the words from the passwd entry GECOS string of the user.
# The check is enabled if the value is not 0.
gecoscheck = 1
#
badwords = passwords pass 123456 1234 word hola adios rio pan manzana pera
```

Figura 14. Archivo pwquality.conf configurado para robustez de contraseñas.

Con el difok le indicamos que la nueva contraseña debe diferir en al menos 5 caracteres de la anterior. El minlen especifica la longitud mínima de 15 caracteres. Con los parámetros de credit le indicamos que tenga mínimo 2 dígitos, mayúsculas, minúsculas y símbolos. Para que use 4 clases de caracteres se especifica con minclass. Por el contrario, maxclass dice que tiene que haber como máximo dos veces consecutivas cada carácter, y el maxclassrepeat no deja repetir más de cuatro caracteres de la misma clase seguidos. Evitamos que datos personales estén en la contraseña con gecosccheck. Y badwords prohíbe las palabras especificadas.

Una vez configurado, podemos editar el common-password para que utilice pwquality y el historial. Le indicaremos los intentos permitidos para cambiar la contraseña antes de fallar y evitaremos reutilizar las últimas 5 contraseñas.

```
# here are the per-package modules (the "Primary" block)
password      requisite                                pam_pwquality.so retry=3
password      required                                pam_pwhistory.so remember=5 use_authtok
password      [success=1 default=ignore]              pam_unix.so obscure use_authtok try_first_pass yescrypt
# here's the fallback if no module succeeds
```

Figura 15. Archivo common-password configurado para robustez de contraseñas.

Lo siguiente que haremos será modificar el login.defs para indicar la caducidad de 90 días para la contraseña, evitar cambios repetidos inmediatos, y habilitar avisos 7 días antes de la caducidad.

```
PASS_MAX_DAYS    90
PASS_MIN_DAYS    1
PASS_WARN_AGE    7_
```

Figura 16. Archivo login.defs configurado para robustez de contraseñas.

Para usuarios existentes, se hace con chage especificaremos el mínimo de días antes de cambiar con -m, con -M indicamos el máximo de días, -W es el aviso previo y el -I es la inactividad, que se bloquea la cuenta después de 30 días sin uso.

```
marina@iescamp:~$ sudo chage -m 1 -M 90 -W 7 -I 30 marina
```

Figura 16. Uso de chage para configurar robustez de contraseñas a usuarios existentes.

Para configurar el bloqueo tras intentos fallidos, deberemos usar pam_tally2 o pam_faillock. Para esto, editamos el common-auth y agregamos las siguientes líneas:

```
# end of pam-auth-update config
auth      required pam_faillock.so preauth silent audit deny=5 unlock_time=3600
auth      [success=1 default=bad] pam_unix.so
auth      required pam_faillock.so authfail audit deny=5 unlock_time=3600
```

Figura 17. Archivo *common-auth* para el bloqueo de cuentas.

Con el `deny` indicamos que se bloquee la cuenta después de 5 intentos fallidos, y que se desbloquee con el `unlock_time` tras 60 minutos (3600 segundos). Esto funciona tanto para usuarios normales como para administradores, evitando DoS porque se puede desbloquear manualmente si hay más de un administrador.

Para revisar los intentos fallidos se utiliza “`faillock --user`” y se desbloquea mediante “`faillock --user nom --reset`”.

Vamos a comprobar lo que se nos pide.

Primero el acceso al sistema con un usuario. Creamos un usuario de prueba llamado “`usu_test`”, se solicita una contraseña inicial y se configura el usuario como estándar.

Iniciamos sesión con el nuevo usuario para comprobar los accesos al sistema.

```
login: usu_test
Password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-87-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of dom 14 dic 2025 21:53:10 CET

System load:  0.06          Processes:            120
Usage of /home: 0.0% of 9.75GB Users logged in:          0
Memory usage:  10%         IPv4 address for enp0s3: 192.168.1.162
Swap usage:    0%

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 71 actualizaciones de forma inmediata.
20 de estas son actualizaciones de seguridad estándares.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law
```

Figura 18. Inicio de sesión exitoso con un usuario distinto.

Si intentamos cambiar la contraseña, como no ha pasado ni un día, nos mostrará un error.

```
usu_test@iescamp:~$ passwd
Changing password for usu_test.
Current password:
You must wait longer to change your password.
```

Figura 19. Fallo al intentar cambiar la contraseña.

Para seguir vamos a comprobar que el usuario creado tiene los cambios de contraseñas configurados correctamente. En este caso solo saldrá que tiene la contraseña como máximo 90 días, como mínimo 1 día y se le avisará con 7 días de antelación antes de que caduque.

```
marina@iescamp:~$ sudo chage -l usu_test
Last password change                : dic 14, 2025
Password expires                    : mar 14, 2026
Password inactive                   : never
Account expires                    : never
Minimum number of days between password change : 1
Maximum number of days between password change : 90
Number of days of warning before password expires : 7
```

Figura 20. Configuración del usuario usu_test con las configuraciones

A continuación, podemos comprobar una serie de contraseñas, para ver que no pasan los niveles de seguridad mínimos establecidos.

```
marina@iescamp:~$ echo "pass" | pwscore
Password quality check failed:
The password contains less than 2 digits
marina@iescamp:~$ echo "password" | pwscore
Password quality check failed:
The password contains more than 4 characters of the same class consecutively
marina@iescamp:~$ echo "pass1word" | pwscore
Password quality check failed:
The password contains less than 2 digits
marina@iescamp:~$ echo "Pass1word" | pwscore
Password quality check failed:
The password contains less than 2 digits
marina@iescamp:~$ echo "Pass1word2" | pwscore
Password quality check failed:
The password contains less than 2 uppercase letters
marina@iescamp:~$ echo "Pass1Word2" | pwscore
Password quality check failed:
The password contains less than 2 non-alphanumeric characters
marina@iescamp:~$ echo "Pass1*Word2*" | pwscore
Password quality check failed:
The password is shorter than 15 characters
marina@iescamp:~$ echo "Pass1*Word2*22a3" | pwscore
Password quality check failed:
The password contains forbidden words in some form
marina@iescamp:~$ echo "Abcf2*rAce5*22a3" | pwscore
40
marina@iescamp:~$ echo "22sK#er$Tuisa25f%gsdauLAsh25$" | pwscore
Password quality check failed:
The password contains more than 4 characters of the same class consecutively
marina@iescamp:~$ echo "22sK#er$Tui25f%gsduLAsh25$sa" | pwscore
57
marina@iescamp:~$ echo "22sK#er$Tui25f%gsdu89*LAsh25$sa" | pwscore
83
marina@iescamp:~$ echo "22sK#er$Tui25f%gsdu89*LAsh25$sa*As7(0a?" | pwscore
100
```

Figura 21. Prueba de contraseñas.

8. Apartado 7.

Por defecto, el usuario root puede cambiar su contraseña incumpliendo la política de complejidad, ya que algunas configuraciones del PAM omiten la verificación para root mediante pam_rootok.so.

Podemos modificar el archivo /etc/pam.d/common-password para incluir el parámetro enforce_for_root en la línea de pam_pwquality.so, asegurando que root también deba cumplir los requisitos.

```
# here are the per-package modules (the "Primary" block)
password    requisite                       pam_pwquality.so retry=3 enforce_for_root_
password    required                       pam_pwhistory.so remember=5 use_authtok
password    [success=1 default=ignore]     pam_unix.so obscure use_authtok try_first_pass yescrypt
# here's the fallback if no module succeeds
```

Figura 22. Configuración PAM con enforce_root.

Al intentar cambiar la contraseña root a una débil, como root123, no debe dejarnos.

```
marina@iescamp:~$ sudo passwd root
New password:
BAD PASSWORD: The password contains less than 2 uppercase letters
New password:
```

Figura 23. Rechazo de contraseña débil para root.

Pero sí debe dejarnos si la contraseña cumple con los requisitos.

```
marina@iescamp:~$ sudo passwd root
New password:
BAD PASSWORD: The password contains less than 2 uppercase letters
New password:
BAD PASSWORD: The password is shorter than 15 characters
New password:
Retype new password:
passwd: password updated successfully
```

Figura 24. Cambio de contraseña para el root exitoso.

9. Conclusiones

La implementación de políticas de contraseñas es esencial para garantizar la protección de los sistemas. Sobre todo para ataques de fuerza bruta y accesos no autorizados.

En esta práctica, hemos añadido configuraciones específicas tanto en Windows como en Linux, cumpliendo con estándares de complejidad, longitud y rotación de contraseñas.

Las pruebas muestran el correcto funcionamiento garantizando a nuestro centro educativo, una configuración de contraseñas robusta.

10. Webgrafía

Orin-Thomas, "Configuración de directivas de contraseña específicas para Servicios de dominio de Active Directory en Windows Server." Available: <https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/get-started/adac/fine-grained-password-policies> . [Accessed: Dec. 14, 2025]

"Ubuntu Manpage: pam_pwquality - PAM module to perform password quality checking." Available: https://manpages.ubuntu.com/manpages/jammy/man8/pam_pwquality.8.html . [Accessed: Dec. 14, 2025]

"CCN-CERT - Disponible la Guía de aplicación de perfilado de Seguridad para Windows Server 2019." Available: <https://www.ccn-cert.cni.es/es/seguridad-al-dia/novedades-ccn-cert/11907-disponible-la-guia-de-aplicacion-de-perfilado-de-seguridad-para-windows-server-2019?format=html> . [Accessed: Dec. 14, 2025]

"Políticas de seguridad para la pyme | Empresas | INCIBE." Available: <https://www.incibe.es/empresas/herramientas/politicas> . [Accessed: Dec. 14, 2025]

"Untitled," need-to-set-password-complexity-for-root-in-ubuntu-20-04. Available: <https://askubuntu.com/questions/1479361/need-to-set-password-complexity-for-root-in-ubuntu-20-04> . [Accessed: Dec. 14, 2025]

Contenidos de la UT3.